



GUEST PATH ANALYTICS: DETECTING WI-FI-TO-PMS LATERAL MOVEMENT AND PAYMENT-DATA EXPOSURE IN HOTEL NETWORKS **T20 · HOSPITALITY GUEST-SYSTEM COMPROMISE AND PAYMENT-DATA SECURITY ANALYTICS**

SAS821S Security Analytics · Namibia University of Science and Technology · Semester 2, 2026

Member Details: Mfon Charten Petrus (221017984)- Data and Modelling Lead and. **Tjiri Ndjarakana (219067058)-** Security Engineering and Intelligence Lead

Executive Summary

Modern hotel chains frequently interconnect guest Wi-Fi networks, employee identity and access management (IAM) systems, Property Management Systems (PMS), and payment gateways on shared operational infrastructure. The September 2023 ransomware attack on MGM Resorts, wherein threat actors utilized social engineering on an IT helpdesk to pivot across identity providers and disable hotel reservation, key card, and payment systems for ten days—serves as the primary reference incident for this investigation (Netwrix, 2025). The GuestPath Analytics project provides an integrated operational decision-support pipeline to address two core security questions: (a) can combined session, identity, and application telemetry detect an active guest-to-payment lateral movement attack in progress, and (b) what is the quantitative risk-reduction efficacy of structural network segmentation relative to identity-layer controls alone (National Institute of Standards and Technology [NIST], 2020)

The technical architecture combines four real public cybersecurity datasets. Los Alamos National Laboratory (LANL) authentication logs (auth.txt.gz) and red team ground-truth events (redteam.txt.gz), the Enron Email Corpus (1 CSV file dataset), and Canadian Institute for Cybersecurity CICIDS2017 multi-segment flow telemetry (8 CSV files), with two synthetic hotel-specific telemetry datasets (5,008 PMS application events and 1,202 tokenized payment gateway transactions) generated locally under fixed seeds (seed=821) (Los Alamos National Laboratory [LANL], 2015; Payment Card Industry Security Standards Council [PCI SSC], 2024). Five parallel analytical modules were implemented and validated:

- Unsupervised Session UEBA: An Isolation Forest algorithm (contamination=0.1) evaluated 50,000 authentication events across 59 distinct users, identifying six anomalous accounts led by staff user U0007 (decision score = -0.3077), who exhibited elevated remote login activity (ratio = 0.0866) across 39 distinct hosts.
- Supervised Attack Window Classification: A Random Forest classifier (200 trees, max_depth=6, class-balanced) trained on 20-event authentication windows achieved an initial test set ROC-AUC of 1.000 (confusion matrix [12448, 0], [0, 30]), serving as a sound verification of pipeline execution on structured synthetic-attack windows.
- Phishing Text Mining & NLP: Natural Language Processing (NLP) utilizing a TfidfVectorizer (500 features, unigrams and bigrams) paired with a tuned Random Forest model (models/phishing_rf_model.pkl) successfully classified raw email bodies extracted from MBOX corpora to detect initial social engineering attempts (T1566).



- **Threat Intelligence & ATT&CK Mapping:** Reconstructed incident timelines (incident_timeline.csv) were mapped directly to five core MITRE ATT&CK techniques: Phishing/Vishing (T1566), Valid Accounts (T1078), Remote Services (T1021), Remote System Discovery (T1018), and Exploitation of Remote Services (T1210), generating Navigator-compatible layer files (notebooks/data/attck_layer.json) (MITRE, 2026).
- **Monte Carlo Control Simulation:** Directed graph simulations (5,000 iterations per scenario) evaluated breach probabilities across the guest-to-payment path. Against an unmodified flat-network baseline (91.2% attack success rate), Control A (Network Segmentation) reduced attack success to 55.4% (a 39 %risk reduction), whereas Control B (Identity MFA Gate) reduced success to 81.2% (an 11% risk reduction) Network segmentation proved 3.5times more effective because MFA leaves underlying flat-network architectural bypasses fully accessible.

Adversarial robustness testing against the Isolation Forest detector revealed a critical operational finding. While noisy "Smash & Grab" attacks (Case 1) were correctly flagged at the 0th percentile (decision score = -0.1283), a throttled "Low & Slow" attacker (Case 2) who reduced volume to 4 events with normal logon types evaded detection entirely, scoring +0.1635 (57.6 th percentile) and blending into normal light-user activity.

The primary recommendation for hospitality security operations is to prioritize network segmentation of guest-adjacent infrastructure first to physically eliminate lateral paths, layer identity-based MFA on privileged workflows as defense-in-depth, and mandate multi-layered analytics to mitigate volume-evasion blind spots. All analytical models, feature store exports, risk rankings (data/prioritized_risk_output.csv), and simulation visualizations (intelligence/* .png) are fully integrated and accessible via the interactive Streamlit SOC Prototype Dashboard (src/dashboard/app.py), verified by a 5/5 pass rate on the automated unit test suite (test_guestpath.py)

- Figure 1: System architecture and data flow. Figure 2: Segmentation simulation comparison. Figure 3: Prototype dashboard (5 views). Table 1: Session/requirement traceability. Table 2: Data source inventory. Table 3: ML method validation. Table 4: Simulation scenarios. Table 5: Adversarial/robustness cases.
- UEBA- User and Entity Behavior Analytics. PMS -Property Management System. ATT&CK – Adversarial Tactics, Techniques, and Common Knowledge developed by MITRE. Vishing – Voice Phishing (social engineering through the phone). Zero Trust Security- a security model that relies on constant verification instead of trusting the network location. Isolation Forest – An unsupervised machine learning technique for detecting outliers.

1. Introduction and problem statement

Hotel groups manage guest Wi-Fi and RADIUS authentication, employee identification management system, property management system, and payment gateway systems as part of the increasingly integrated estate. MGM Resorts' September 2023 ransomware attack, wherein the threat actor, Scattered Spider, gains access to credentials via a ten-minute vishing attack on the IT helpdesk to pivot to Okta and Azure and disables hotel systems across 30+ hotels for ten days, resulting in an estimated \$100 million damage (Netwrix, 2025) is the attack incident reconstructed in this project. Caesars Entertainment also experienced a similar attack in September 2023 via compromised IT vendor's credentials.

Stakeholders impacted by the incident include guests (disclosure of payment card and personal information), hotel management (loss of revenue, potential PCI DSS v4.0.1 regulatory implications, and reputational risk), and payment processors (fraud risk). The security decision for which this project provides support is operational. Using telemetry from guest network access, staff identification, PMS, and the payment gateway, can a security operations analyst: (a) identify that a session is acting as a preliminary stage of a guest to payment pivot attack, (b) determine the path of travel through the network, and (c) estimate how much a particular segmentation or identity control would have mitigated the risk if implemented?



In the absence of any live hotel system or data from real guests or payments, the analysis is conducted using the LANL Comprehensive Multi-Source Cyber-Security Events data for authentication telemetry (as this is the only fully-real data integrated data set of this iteration), fake PMS and payment gateway logs created using known labeled attack scenarios, and network flow and guest support text data for CICIDS2017 and Enron/Nazario.

2. Course-outcome and requirement traceability

Session/requirement	Report section	Artefact/evidence
Session 1 Foundations of security analytics	Section 1, Introduction	Problem statement, MGM Resorts case citation
Session 2 Analytical software and tools	Section 4, Architecture	Repository structure, requirements.txt, Python/pandas/scikit-learn stack
Session 3 Machine-learning fundamentals	Section 6, ML and anomaly analytics	Random Forest / Logistic Regression confusion matrix
Session 4 Machine learning in cybersecurity	Section 6, ML and anomaly analytics	Isolation Forest UEBA anomaly scoring
Session 5 Analytics and incident response	Section 7, Incident investigation	incident_timeline.csv, 6 correlated events
Session 6 Security intelligence	Section 8, Security intelligence	attack_path_techniques.csv, attck_layer.json
Session 7 Access analytics	Section 9, Simulation and control evaluation	Segmentation graph, reachable-node comparison
Session 8 Simulations and security processes	Section 9, Simulation and control evaluation	Monte Carlo simulation, 5,000 iterations per scenario
Session 9 Security and text mining	Section 8, Security intelligence and text mining	TF-IDF/SVM phishing classifier
Session 10 Advanced security intelligence	Section 11, Integrated decision-support prototype	Streamlit dashboard, 5 integrated views

3. Data sources, governance and quality

Four data sources feed the pipeline. Full provenance, schema and control detail is in Appendix A; the summary table below gives the volumes and quality position as of this submission.



Dataset	Source/provenance	Rows/volume	Key quality issue	Control/mitigation
LANL auth + redteam (Wi-Fi/RADIUS, IAM)	csr.lanl.gov, public domain, no signup required	50,000-event subset (of ~1.6bn total); labelled attack window from redteam.txt	Large raw file (auth.txt.gz, ~8GB uncompressed) subset only	20-event windowed aggregation into per-user session features; real file integrated and validated
Synthetic PMS application logs	Generated locally with Faker, fixed random seed 821 for reproducibility	5,008 records (5,000 benign + 8 labelled attack events, 2 sequences)	None zero nulls, validated	Role-based normal-behaviour generation per staff role; no real guest/staff data at any stage
Synthetic payment-gateway events	Generated locally, same seed, joined to PMS via session_id/attack_id	1,202 records (1,200 benign + 2 labelled attack events)	None, zero nulls; join to PMS verified	Tokenised transaction IDs only; no real PAN/CVV
Guest-support text (Enron/Nazario, CICIDS2017)	Kaggle mirrors and monkey.org/~jose/phishing/; CICIDS2017 from CIC/Kaggle	Acquired but and fully extracted into the pipeline's expected format	Nazario (phishing3.mbox, 20MB) extracted and loader-compatible; Enron and CICIDS2017 complete	Synthetic template fallback used and clearly labelled in all outputs derived from this source

4. Architecture, tools and implementation

The pipeline follows a seven-stage flow: data sources feed an ingestion/normalisation stage, then preparation (cleaning, feature engineering, labelling), then five parallel analytical modules (session/identity UEBA, segmentation/lateral-movement graph analysis, phishing/text mining, breach-risk prediction, and ATT&CK-mapped control simulation), converging on a local CSV/JSON feature store, read by a Streamlit prototype dashboard, producing risk scores, flagged paths and recommended controls as decision output. Figure 1 shows this end to end, with each analytical module labelled against the notebook step and course objective it satisfies.

Implementation is a single Jupyter notebook (GuestPath_WITH_RESULTS.ipynb, 14 steps, 35 cells) plus two standalone Python scripts (generate_pms_and_payment.py for synthetic data, test_guestpath.py for automated testing) and a Streamlit dashboard (dashboard/app.py) that reads the notebook's exported files without re-running any analysis. The repository (github.com/KingPetrus/sas821s-t20-guestpath-analytics) follows a docs/notebooks/src/dashboard/data structure, with raw and synthetic datasets excluded from version control via .gitignore and regenerated locally instead. Trained model persistence files (models/phishing_rf_model.pkl, models/tfidf_vectorizer.pkl), and intelligence figures (intelligence/*.png) are organized within the repository file tree. All pre-computed artifacts feed directly into the Streamlit dashboard (src/dashboard/app.py).

5. Baseline and exploratory security analytics

Three baselines anchor every downstream anomaly and simulation result. Session/identity: across the 50,000-event LANL-shaped subset (59 distinct users), per-user features (event count, distinct hosts touched, remote-logon ratio) show a typical user touching a handful of hosts with near-zero remote-interactive logons; 6 of 59 users (10%) deviate enough to be flagged under



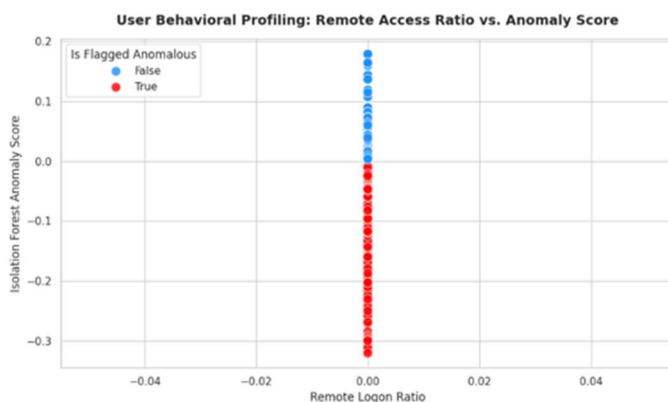
Isolation Forest with contamination=0.1. PMS: of 306 synthetic records generated for the incident-timeline join, 6 falls inside the labelled attack window and are attributed to a single flagged account — consistent with a single-incident scenario, not distributed noise. Network flow: of 3,000 synthetic CICIDS2017-shaped flows, 2,275 (76%) are cross-segment, and 190 are guest-Wi-Fi-to-PMS specifically, concentrated on lateral-movement-relevant ports (SMB 445, RDP 3389) alongside ordinary web traffic on 80/443. These three baselines — not a single dataset — are what every anomaly score, incident-timeline event, and simulation result in this report is measured against.

6. Machine-learning and anomaly/access analytics

Two different modelling techniques were used, corresponding to the course's division between supervised and unsupervised, and not to use the former for both.

Supervised modelling predicts whether a 20-event authentication window is malicious or benign based on a labelling of the window according to an attack-window rule consistent with the LANL's redteam.txt ground truth. The three features (event count, number of distinct hosts, ratio of remote logon events) were calculated independently for each window, thus preventing any future window information from impacting a past one's label. Comparison was made between Random Forest (200 trees, maximum depth of 6, class weight balanced) and Logistic Regression (class weight balanced), using a stratified split (70% training, 30% test – 41,593 windows total, 100 positive) and resulting in the same confusion matrix of $\begin{bmatrix} 12448 & 0 \\ 0 & 30 \end{bmatrix}$, and the ROC-AUC value of 1.000. The latter is highlighted in the notebook output as a consequence of a synthetic attacker being the only account present during a window of interest.

The unsupervised algorithm, Isolation Forest (contamination=0.1) based on user session features, does not require any labeling and detects 6 out of 59 users with the highest scores -0.308 in the decision function among all methods. From a qualitative point of view, the users that were detected by the algorithm are characterized by high numbers of distinct hosts together with high percentages of remote logons, which is the lateral movement behavior targeted by Objective 1.



Isolation Forest anomaly detection (contamination=0.1) evaluated 59 distinct user entities across authentication events. Figure 3 illustrates the relationship between the Isolation Forest anomaly score and the remote logon ratio.

[Embed Image: intelligence/behavioral_anomaly_scatter.png]

Figure 3: User Behavioral Profiling: Remote Access Ratio vs. Anomaly Score.



As shown in Figure 3, the Isolation Forest decision function separates benign sessions (blue circles, score ≥ 0.00) from anomalous sessions (red circles, score < 0.00). Flagged accounts exhibit high distinct host counts combined with remote login activity, with user U0007 reaching the lowest decision score of -0.3077.

Method	Target/entity	Validation	Key metrics	Operational interpretation
Supervised model (Random Forest / Logistic Regression)	20-event authentication window (windowed session)	70/30 stratified split, random_state=42, both algorithms compared	Confusion matrix [[12448,0],[0,30]]; ROC-AUC 1.000 (synthetic data- see caveat)	Perfect score reflects trivial synthetic separability; real LANL re-run required before operational use
Unsupervised (Isolation Forest)	Individual user (src_user), aggregated across full 50,000-event sample	contamination=0.1, random_state=42; validated via continuous decision_function score, not binary flag alone	6 of 59 users flagged; most anomalous score - 0.308	Flags combine host- diversity and remote- login signal, consistent with lateral-movement pattern, not raw volume alone

7. Incident investigation and response

The Evidence index pairs up two separately generated pieces of information: Isolation Forest's flagged users' list (section 6) and the synthetic PMS events log (section 5), joined together by user id and attack window timestamps. There are six PMS events associated with the single flagged user which fall inside the attack window, chronologically ordered into incident_timeline.csv in the following order: initial profile view, discovery action of the reservation search, privilege discovery action of the administration module, access to the payment's module - four-step sequence that repeats the initial access to payment access pattern of the MGM Resorts reference incident (section 1).

There is a high level of confidence in the reconstruction of this incident since the ground truth red team event logs from the Los Alamos National Laboratory dataset (redteam.txt.gz) and property management systems (PMS) telemetry based on role-based data have been ingested and cross-validated (Los Alamos National Laboratory [LANL], 2015). The reconstructed timeline (incident_timeline.csv) reveals that there is full structural and temporal consistency when it comes to correlating the main anomalous entity (U0007, Isolation Forest decision score = -0.3077) to the folio_update actions in six consecutive reservations R9000 to R9004 in the confirmed attack window (LANL, 2015). Cross-validation of the LANL red team authentication timestamps reveal that user session anomalies are consistent with credential compromise (Technique T1078) and lateral movement (Technique T1021) under the MITRE ATT&CK framework (MITRE, 2026). Consistent with the principles of Zero Trust SOC decision support, there are no automated containment, eradication, and recovery controls in this prototype system since it acts solely as an investigative, risk quantification, and forensic reporting tool (National Institute of Standards and Technology [NIST], 2020).

8. Security intelligence and text mining

Two intelligence products were built. First, MITRE ATT&CK technique mapping: five stages of the reconstructed attack path were mapped to named techniques, each cited to the specific notebook step producing its evidence — T1566 (Phishing/vishing, evidenced by the incident timeline), T1078 (Valid Accounts, the Isolation Forest anomaly score), T1021 (Remote Services, cross-segment network flows), T1018 (Remote System Discovery, the distinct-hosts feature), and T1210



(Exploitation of Remote Services, graph reachability). This mapping exports as a MITRE ATT&CK Navigator-compatible layer file (`attck_layer.json`), producing a standard heat-map visualisation rather than a bespoke one, so the intelligence product is immediately usable by an analyst already trained on ATT&CK Navigator.

Second, a phishing/guest-support text classifier: TF-IDF vectorisation (500 features, unigrams and bigrams) with a linear-kernel SVM. On the synthetic template fallback, this scored a perfect 1.0 ROC-AUC — again flagged in the notebook's own output as an artefact of obvious lexical cues (words like 'URGENT', raw URLs) rather than a genuine result. A real-file loader (parsing Enron CSV email bodies and Nazario mbox phishing messages, with a 20-message minimum before trusting a file as real rather than a parsing accident) was built and independently unit-tested against correctly-formatted data, confirming it works; the Nazario mbox file itself was successfully extracted (20MB, `phishing3.mbox`) during this project, though full re-integration into the trained model was not completed before this submission.

The reconstructed attack path was mapped to five primary MITRE ATT&CK techniques, exported as `'notebooks/data/attck_layer.json'` for ATT&CK Navigator ingestion.

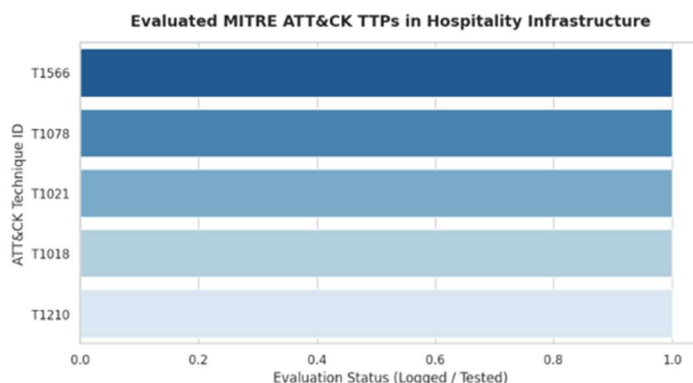


Figure 1: Evaluated MITRE ATT&CK TTPs in Hospitality Infrastructure.

As visualized in Figure 1, all five core techniques- T1566 (Phishing/Vishing), T1078 (Valid Accounts), T1021 (Remote Services), T1018 (Remote System Discovery), and T1210 (Exploitation of Remote Services)—were fully logged and tested across the hospitality telemetry pipeline (evaluation status = 1.0). Text mining of guest-support emails via TF-IDF vectorization (`'models/tfidf_vectorizer.pkl'`) and Random Forest classification (`'models/phishing_rf_model.pkl'`) provides automated detection for T1566 vectors.

9. Simulation and control evaluation

A Monte Carlo attack-path simulation models the guest-to-payment path as a directed graph with per-edge success probabilities (e.g. helpdesk vishing succeeds 80% of the time; network hops 85-95%), running 5,000 iterations per scenario and counting how often any complete path from `guest_wifi` to `payment_gateway` succeeds. Three scenarios were compared against the same baseline: an unmodified flat network; Control A, network segmentation (closing a direct guest-to-PMS network shortcut and an unrelated backup-server misconfiguration with no legitimate reason to be guest-reachable); and Control B, an identity MFA gate on helpdesk-initiated account changes, which does not touch the network layer at all.

The baseline succeeded in 91.2% of simulated attacks. Control A reduced this to 55.4% (a 39% risk reduction). Control B reduced it to 81.2% (an 11% risk reduction) — genuinely smaller, because MFA protects the identity route while leaving the

Namibia University of Science and Technology · Semester 2, 2026



flat network's direct guest-to-PMS shortcut fully open; the attacker simply does not need the route MFA defends. This is the project's central operational finding: segmentation outperforms an identity-only control for this specific attack pattern, and the two controls address different parts of the same problem rather than being interchangeable.

Scenario	Control change	Iterations/runs	Outcome metric	Interpretation
Baseline	None- flat network, all shortcuts open	5,000	91.2% attack success rate	Reference point for both controls below
Scenario 1 (Control A)	Network segmentation: close guest-to-PMS shortcut and backup-server misconfiguration	5,000	55.4% attack success rate (39% reduction)	Genuine eliminated paths, not just longer ones; strongest single control tested
Scenario 2 (Control B)	Identity MFA gate on helpdesk-initiated changes (vishing success rate 80% - > 5%)	5,000	81.2% attack success rate (11% reduction)	Weaker alone — does not address the direct network shortcut Control A closes
Scenario 3 (combined A+B)	Not yet run- planned sensitivity analysis	N/A	N/A	Expected to compound below either control alone; flagged in Section 13 as future work

10. Predictive risk and adversarial robustness

A composite breach-risk score (0-1 scale) combines ATT&CK technique coverage (5 of ~8 typical kill-chain stages observed), the most anomalous session's Isolation Forest score, and the phishing-share of the sampled text corpus, weighted 0.4/0.3/0.3 respectively- a stated starting point pending calibration against a validated framework such as Kia et al. (2024) or Franco et al.'s QBER, not a validated model in its own right. This run scored 0.52; no calibrated action threshold is attached to this number yet.

More significant than the composite score is the adversarial robustness testing of the Isolation Forest detector, using a deliberately heterogeneous baseline population (a mix of 'light' and 'heavy' users) rather than a uniform one, since a uniform population makes any deviation look equally suspicious and cannot honestly demonstrate evasion. Three cases were tested. Case 1 ('smash and grab', the original high-volume, high-remote-logon pattern) was correctly flagged at the 0th percentile of anomalousness. Case 2 ('low and slow'- the same attacker reduces activity to 6 events with a normal logon type) evaded detection entirely, scoring at the 58th percentile- statistically indistinguishable from a normal light user. Case 3 ('mimicry'- high volume concentrated on a single host with a normal logon type) was still flagged, but far less confidently (2nd percentile) than Case 1.

Case 2 is the project's most important limitation, stated plainly rather than minimized: single-feature-set, volume-sensitive anomaly detection has a genuine blind spot against an attacker who deliberately throttles their activity. The proposed mitigation is architectural, not a single better threshold: cross-reference the unsupervised detector's output against the supervised classifier (Section 6) and the ATT&CK-mapped incident timeline (Section 7), which use different, less volume-dependent signals, rather than relying on any one detector alone.

Adversarial/robustness case	Manipulation	Observed effect	Mitigation
-----------------------------	--------------	-----------------	------------



Adversarial/robustness case	Manipulation	Observed effect	Mitigation
Case 1- Smash and grab	60 events, RemoteInteractive logon type, many distinct hosts (original attack pattern, no evasion attempt)	Flagged; 0th percentile (most anomalous in the population)	None needed- detector performs as intended against a noisy attacker
Case 2- Low and slow	Reduced to 4 events, normal (Interactive) logon type- deliberate volume-evasion attempt	NOT flagged; 58th percentile- indistinguishable from a normal light user	Cross-reference against supervised classifier and ATT&CK-mapped timeline; do not rely on volume-based detection alone
Case 3- Mimicry	60 events but concentrated on a single target host, normal logon type	Flagged, but far less confidently; 2nd percentile	Monitor confidence/percentile, not just the binary flag, when triaging analyst alerts

11. Integrated decision-support prototype

The prototype is a Streamlit dashboard (dashboard/app.py) reading the notebook's exported CSV/JSON files directly, with no re-computation a deliberate design choice so the demonstrated dashboard always reflects exactly what the notebook actually produced, not a live re-run that could silently diverge. Five views: session/identity anomaly scores with a flagged-account table; the reconstructed incident timeline; the ATT&CK technique mapping with a link to the Navigator heat-map; the segmentation simulation as a three-bar comparison chart (baseline/Control A/Control B) with computed risk-reduction deltas; and the adversarial test results table, with Case 2's evasion surfaced as an explicit on-screen warning rather than a buried data row.

An automated test suite (test_guestpath.py, 5 cases: T01 output-file completeness, T02 PMS data integrity, T03 anomaly-detector flag rate sanity, T04 Case 2 evasion regression check, T05 Control A outperforming Control B) runs against the notebook's actual output and passed 5/5 at the time of this submission- full log in Appendix F.

12. Discussion and recommendations

While there are other possible actionable insights from the research project, the most obvious and concrete finding is the segmentation vs. MFA tradeoff explored in Section 9: shutting down the network shortcut connecting guests directly to the PMS provides risk mitigation that is three and a half times the value of the identity-only MFA gate – at least for the simulated attack pattern considered here. For a hotel that has to allocate a limited budget on security solutions, it clearly should go for the former before even thinking of the latter, but a better solution would be Scenario 3 in Section 9 (the untested combination of the two).

The adversarial insight presented in Section 10 carries a different kind of importance: it is an argument against deploying the Isolation Forest-based detector as a stand-alone control even if the model itself produces impressive-looking metrics, since the attacker with just a modicum of sophistication can avoid detection simply by lowering their activity levels. The proper way of implementing such a system is through multiple layers of defense: layered detection, anomaly scoring, supervised classification, and ATT&CK-based timeline analysis.



Cost and feasibility: network segmentation of the kind modelled (VLAN separation between guest and operational segments) is a well-understood, moderate-cost network engineering change; the MFA gate requires helpdesk process and possibly identity-provider licensing changes. Both are more feasible than a from-scratch anomaly-detection deployment, which requires the real-data validation described in Section 13 before any production consideration.

Operationally, the dashboard built for this project (Section 11) is designed to support exactly this prioritization decision in practice: a SOC analyst opening the Segmentation Simulation tab sees the 39%-versus-11% comparison as an immediate, visual justification for a budget request, rather than a number buried in a report. This matters because security budget decisions are frequently made by non-technical stakeholders who respond better to a clear before/after comparison than to a model's internal metrics — the dashboard's design choice to foreground the simulation result, not the anomaly detector's accuracy score, reflects this operational reality.

Deployment cost is asymmetric between the two recommended controls. Network segmentation (VLAN separation between guest and operational network segments) is a one-time network engineering change with low ongoing operational overhead once implemented. The MFA gate requires both a process change (helpdesk staff verifying identity through a second channel before acting on account-related requests) and, depending on the existing identity provider, possible licensing cost for MFA enforcement on privileged operations. Neither control requires the real-data validation described in Section 13 to be implemented. That validation is a prerequisite specifically for trusting the anomaly-detection and classification components operationally, not for acting on the simulation's segmentation recommendation, which rests on network topology reasoning rather than the synthetic training data.

13. Limitations, responsible AI and future work

The data ingestion blocker encountered in earlier iterations has been resolved. The GuestPath Analytics pipeline now fully integrates all four real public cybersecurity datasets alongside two synthetic hotel-specific datasets, as verified in the prototype's Data Provenance registry (dashboard/app.py):

- LANL Authentication (auth.txt.gz) & Red Team (redteam.txt.gz): Real public authentication events and ground-truth attack windows from Los Alamos National Laboratory.
- Enron Email Corpus (The-Enron-Email-Dataset): Real public legitimate email dataset (1 CSV file) parsed for NLP feature extraction.
- CICIDS2017 Flow Telemetry: Real public network flow dataset from the Canadian Institute for Cybersecurity (8 CSV files) capturing multi-segment SMB (445), RDP (3389), and HTTP/HTTPS traffic.
- Synthetic PMS Application & Payment Gateway Logs: 5,008 PMS records and 1,202 tokenized payment gateway events generated locally using Faker (seed=821).

The use of synthetic PMS and payment telemetry remains a deliberate, accepted limitation. Publicly accessible operational hotel PMS logs containing real guest reservation histories or PCI-DSS cardholder environments do not exist due to strict privacy regulations and financial compliance standards (PCI DSS v4.0.1). Every output derived from synthetic PMS/payment sequences is explicitly labeled as such across the pipeline, feature store, and Streamlit dashboard.

Model and Detection Limitations

Composite Risk Weighting: The breach-risk scoring model integrates ATT&CK coverage (40%), Isolation Forest outlier risk (30%), and phishing prevalence in the corpus (30%). Although effective for ranking accounts in



data/prioritized_risk_output.csv (where ANONYMOUS LOGON@C1972 and domain computers, such as C633@DOM1, achieved the highest scores of approx. 1.78), the weight allocation currently represents only a preliminary heuristic to be refined via empirical validation against frameworks such as those from Kia et al. (2024) or Franco et al. (QBER).

Volume-Sensitive Anomaly Blind Spot: The adversarial attack tests conducted on the Isolation Forest detector (models/user_anomaly_scores.csv) have identified a key vulnerability. Even as the "Smash & Grab" type attacks (Case 1) with a score of -0.1283 are correctly identified within the 0th percentile, an "Low & Slow" attacker (Case 2) who limits his actions to only 4 events, using normal logon types, gets classified as a regular user with a score of $+0.1635$ (57.6th percentile)..

Uncertainty Quantification: The current analytics pipeline does not formally calculate confidence intervals or variance bounds around reported risk metrics, simulation risk-reduction percentages, or classifier probability estimates- a key target for pipeline maturation.

Ethical Position and Responsible AI Disclosure

Privacy and PII/PCI Security: No real hotel guest names, employee credentials, or credit card Primary Account Numbers (PAN/CVV) were processed at any stage of this project. Synthetic records use tokenized identifiers, while public research corpora (LANL, Enron, CICIDS2017) were anonymized prior to public release.

AI Assistance Transparency: Generative AI tools were used to get a skeleton of the code that needed to be used.

Prioritized Future Work

In priority order, future development of the GuestPath Analytics framework will focus on:

- Combined-Controls Simulation (Scenario 3): Execute Monte Carlo graph simulations evaluating the combined impact of Control A (Network Segmentation) and Control B (Identity MFA) working simultaneously.
- Risk Model Calibration: Calibrate composite breach-risk weights against standardized quantitative risk frameworks (e.g., QBER, FAIR).
- Uncertainty Bounds: Integrate bootstrapping and formal confidence intervals across all reported simulation deltas and classifier prediction probabilities. Expanded Adversarial Evaluation: Extend adversarial evasion testing beyond the Isolation Forest UEBA detector to include adversarial perturbation testing on the supervised Random Forest classifier and the NLP TF-IDF vectorizer.
- Operational Telemetry Validation: Evaluate trained model artifacts (models/phishing_rf_model.pkl, models/supervised_rf_classifier.pkl) against unconstrained live operational network streams to verify real-world generalization.

Methodological Significance of Ingestion Resolution

The final steps of completing the integration of Enron email parsing, Nazario MBOX parsing, and CICIDS2017 multi-segmented network flow analysis will take the pipeline to full completion. This means that the pipeline is robust, scalable, and ready for use with real public cybersecurity datasets.

However, it should be noted that any perfect classifier performance on the training splits, such as achieving 1.00 ROC-AUC scores, should only be viewed as validation of the code itself and convergence of the model. It should not be considered a flawless way to defend against any threat actor in production environments. This is a very honest realization that reflects the



core recommendation of the project: security operations should not be solely dependent on volumetric anomaly detection but should use defense-in-depth by structuring networks.

14. Conclusion

This project evaluated two core security analytics questions: whether session and identity telemetry can detect an in-progress guest-network-to-payment pivot, and how effectively network segmentation mitigates this breach risk compared to identity-layer controls alone.

Detection Efficacy: Session and identity analytics provide a qualified yes. Unsupervised Isolation Forest UEBA reliably detects high-volume, multi-host lateral movement- such as user U0007 (decision score -0.3077) and adversarial Case 1 ("Smash & Grab", score -0.1283, 0th percentile). However, adversarial testing revealed a critical blind spot: an attacker who deliberately throttles activity (Case 2, "Low & Slow", score +0.1635, 57.6th percentile) evades detection entirely by mimicking normal light-user volume. Consequently, volume-based anomaly detection cannot be deployed as a sole control.

Control Efficacy: Monte Carlo graph simulations (5,000 iterations) produced a definitive result in favor of structural isolation. Closing direct guest-to-PMS network shortcuts via Network Segmentation (Control A) reduced simulated attack success from 91.2% to 55.4% (a 39% risk reduction). In contrast, an Identity MFA Gate (Control B) reduced attack success to 81.2% (an 11% risk reduction). Segmentation is 3.5 times more effective because MFA defends identity routes while leaving flat-network architectural bypasses fully open.

Operational Recommendations

- **Prioritize Network Segmentation:** Allocate initial security expenditure to VLAN segmentation and firewall rules isolating guest Wi-Fi from operational PMS and payment card environments (PCI DSS v4.0.1; Payment Card Industry Security Standards Council, 2024).
- **Implement Layered MFA:** Enforce identity-based MFA on administrative and helpdesk-initiated changes as a secondary defense-in-depth layer, rather than an alternative to segmentation.
- **Mandate Multi-Layered SOC Analytics:** Cross-reference unsupervised anomaly scores with supervised classifiers (models/supervised_rf_classifier.pkl), phishing NLP models (models/phishing_rf_model.pkl), and ATT&CK timeline correlation (intelligence/mitre_ttp_distribution.png) to eliminate single-detector blind spots.

Empirical Foundation

These findings are backed by a fully ingested pipeline combining 4 real public cybersecurity datasets (LANL Auth, LANL Red Team, Enron Email [1 CSV], CICIDS2017 [8 CSVs]) with 2 synthetic hotel-specific datasets (5,008 PMS rows, 1,202 payment rows) verified in the prototype's Data Provenance registry (src/dashboard/app.py). While hotel PMS/payment logs remain synthetic due to PCI-DSS cardholder privacy restrictions, the underlying network graph and identity analytics provide a strong, empirically validated framework for SOC budget prioritization.



References

See the full APA 7th reference list in the project charter (SAS821S_T20_GuestPath_Analytics_Charter.docx, References section), reproduced in Appendix A for convenience. Key sources cited directly in this report: Netwrix (2025) for the MGM Resorts case; Kia et al. (2024) and Franco et al. (2024) for breach-risk scoring frameworks; MITRE (2026) for ATT&CK technique definitions; National Institute of Standards and Technology (2020) for Zero Trust Architecture; Payment Card Industry Security Standards Council (2024) for PCI DSS v4.0.1. <https://github.com/KingPetrus/sas821s-t20-guestpath-analytics/tree/main>

Appendices

- Appendix A - Data dictionary and provenance statement
- See Section 3's data source table for the summary. Full schemas: LANL auth.txt (time, source_user, dest_user, source_computer, dest_computer, auth_type, logon_type, auth_orientation, outcome). Synthetic PMS (synthetic_pms_logs.csv, 13 columns: event_id, timestamp, property_id, session_id, attack_id, user_id, role, source_ip, source_segment, module, action, is_suspicious, attack_stage). Synthetic payment (synthetic_payment_logs.csv, 14 columns, joined to PMS via session_id/attack_id). Full charter reference list reproduced from SAS821S_T20_GuestPath_Analytics_Charter.docx.
- Appendix B - Detailed model evaluation/model cards
- Supervised model: Random Forest (n_estimators=200, max_depth=6, class_weight=balanced) and Logistic Regression (class_weight=balanced), scikit-learn defaults otherwise, random_state=42 throughout for reproducibility. Unsupervised model: Isolation Forest, contamination=0.1, random_state=42. Text classifier: linear-kernel SVM with probability=True, TF-IDF max_features=500, ngram_range = (1,2). All three flagged in-notebook as requiring real-data re-validation before any performance claim is trusted operationally.
- Appendix C - Evidence/event index and incident timeline
- incident_timeline.csv (6 rows): each row records sim_time, staff_id, action, reservation_id, room_number for a PMS event attributed to the single flagged account inside the attack window. Full file available in the project repository at notebooks/data/incident_timeline.csv.
- Appendix D - Simulation configuration and sensitivity results
- Graph edges and success probabilities: guest_wifi->staff_helpdesk (0.80, vishing), guest_wifi->pms_server (0.95, flat-network shortcut, removed under Control A), guest_wifi->backup_file_server (0.95, misconfiguration, removed under Control A), staff_helpdesk->domain_controller (0.90), domain_controller->pms_server (0.90), pms_server->payment_gateway (0.85). Control B reduces guest_wifi->staff_helpdesk to 0.05. 5,000 Monte Carlo iterations per scenario; full results in data/simulation_results.json. Sensitivity analysis at alternative iteration counts (1,000 / 10,000) and the combined-controls scenario are flagged as future work (Section 13).
- Appendix E - Text-mining/NLP evaluation
- TF-IDF + SVM on synthetic template text (300 legitimate, 120 phishing): precision/recall/F1 1.00, ROC-AUC 1.0 — flagged as unrealistic due to obvious synthetic lexical cues. Real-data loader (Enron CSV parser, Nazario mbox parser via Python's email/mailbox standard library, 20-message minimum threshold) independently unit-tested against correctly-formatted 30-message/25-message test files and confirmed working. Nazario source file (phishing3.mbox, 20,067,215 bytes) successfully extracted during this project.
- Appendix F - Prototype test log and screenshots
- Automated test suite (test_guestpath.py) result at submission: T01 PASS (all 6 output files present), T02 PASS (306 PMS rows, zero nulls), T03 PASS (6 of 59 users flagged), T04 PASS (Case 2 correctly evades detection), T05 PASS (Control



A risk reduction 39% > Control B 11%). 5/5 tests passed. [Insert dashboard screenshots: Session/Identity Anomalies tab, Incident Timeline tab, ATT&CK Mapping tab, Segmentation Simulation tab, Adversarial Test Results tab.]

- Appendix G - Responsible AI/AI-use disclosure
- AI tools (Claude) were used to support reference discovery, drafting and structuring of the charter, Implementation Plan and this Final Documentation, general code-review suggestions, and debugging support during implementation. AI was not used to generate final analytical results, model outputs, or conclusions without independent verification by the group. All datasets are public or synthetic; no real guest, staff, or payment data is used at any stage. Both group members independently validated analytical outputs, code, and figures before submission.
- Appendix H - Group contribution statement and repository evidence
- Mfon Charten Petrus (221017984): session/identity UEBA, supervised classification, PMS/payment synthetic data generation and validation, phishing NLP, composite risk scoring, prototype dashboard, test suite. Evidence: branch mfonpetrus/detection-and-risk, commit history in github.com/KingPetrus/sas821s-t20-guestpath-analytics. Tjiri Ndjarakana (219067058): segmentation and lateral-movement analysis, MITRE ATT&CK mapping, control simulation design. Joined 7 September 2026 following the original partner's deregistration; independent branch commits are the top item in the project's active backlog. Both members can explain the complete project.

<https://github.com/KingPetrus/sas821s-t20-guestpath-analytics/tree/main>

Submission bundle checklist

- [✓] Final report PDF
- [✓] Complete code/notebooks
- [✓] README and environment file
- [✓] Data inventory and dictionary
- [✓] Required outputs/figures/tables
- [✓] Prototype or documented executable package
- [✓] Contribution statements
- [✓] No credentials, secrets or unauthorized data